

An Attacker-Aware Hybrid Framework for Explainable PII and OpSec Risk Detection in Social Media

Kavinga Yapa

*Dept. of Computer Systems Engineering
Sri Lanka Institute of
Information Technology (SLIIT)
Malabe, Sri Lanka
kavinga.y@sliit.lk*

Deemantha Siriwardana

*Dept. of Computer Systems Engineering
Sri Lanka Institute of
Information Technology (SLIIT)
Malabe, Sri Lanka
deemantha.s@sliit.lk*

H. M. G. D. K. Herath

*Dept. of Computer Systems Engineering
Sri Lanka Institute of
Information Technology (SLIIT)
Malabe, Sri Lanka
it22361486@my.sliit.lk*

H. P. G. H. S. De Alwis

*Dept. of Computer Systems Engineering
Sri Lanka Institute of
Information Technology (SLIIT)
Malabe, Sri Lanka
it22317926@my.sliit.lk*

M. R. I. Fernando

*Dept. of Computer Systems Engineering
Sri Lanka Institute of
Information Technology (SLIIT)
Malabe, Sri Lanka
it22366054@my.sliit.lk*

J. R. Vishwa

*Dept. of Computer Systems Engineering
Sri Lanka Institute of
Information Technology (SLIIT)
Malabe, Sri Lanka
it22916112@my.sliit.lk*

Abstract—The increasing use of social media has amplified the risk of unintentional privacy exposure, where seemingly harmless posts can reveal sensitive personal and contextual information. Traditional approaches primarily focus on detecting explicit Personally Identifiable Information (PII), often failing to capture implicit operational security (OpSec) risks arising from contextual and behavioral signals.

This paper presents a hybrid privacy risk detection system that integrates rule-based and machine learning techniques with an attacker-aware reasoning framework. The system combines structured PII detection with contextual OpSec signal extraction and models interactions between multiple signals to assess overall risk. In addition, the system provides user-facing explanations and privacy-preserving rewrite suggestions to support informed decision-making prior to content publication.

The proposed system is evaluated using a controlled dataset of 25 test cases across five categories, including safe, PII, OpSec, combined, and ambiguous scenarios. Experimental results demonstrate an overall accuracy of 72%, with strong performance in multi-signal cases, achieving 100% accuracy in combined PII and OpSec scenarios. The system also produces generally high-quality explanations, though rewrite effectiveness remains inconsistent in certain cases.

The findings indicate that integrating reasoning-based risk composition supports more interpretable detection of privacy risks by combining explicit detection with contextual reasoning. This work highlights the importance of combining detection, contextual reasoning, and user interaction in developing effective privacy-aware systems.

Index Terms—Personally Identifiable Information (PII), Operational Security (OpSec), Contextual Privacy, Social Media Security, Attacker-Aware Reasoning, Explainable AI, Privacy-Preserving Text Rewriting

I. INTRODUCTION

The rapid growth of social media platforms has fundamentally transformed how individuals communicate and share information. However, this increased connectivity has also amplified privacy risks, where users unintentionally disclose sensitive personal and contextual information through everyday posts. Research has shown that human behavior plays a significant role in privacy exposure, often leading to a gap between privacy awareness and actual user practices [1].

A substantial body of work has focused on automated detection of explicit Personally Identifiable Information (PII) using Natural Language Processing (NLP) techniques. Early approaches relied on rule-based methods, while more recent work has leveraged transformer-based models such as BERT for Named Entity Recognition (NER) [2]. These approaches demonstrate strong performance in identifying structured and unstructured identifiers, including names, phone numbers, and email addresses.

However, detecting explicit identifiers alone is insufficient for real-world privacy protection. Studies in contextual privacy and inference attacks show that adversaries can derive sensitive information from combinations of seemingly benign signals [3], [4]. For example, travel plans, real-time location sharing, and routine disclosures can collectively reveal conditions such as absence from home or predictable behavior, even in the absence of direct identifiers.

Existing solutions, including platform moderation systems and data loss prevention tools, are largely reactive and operate after content has already been published. Furthermore, these systems typically provide binary outputs without meaning-

ful explanations or actionable guidance, contributing to user disengagement and security fatigue [5]. Research in usable security highlights the importance of providing interpretable and actionable feedback to support user decision-making [6].

To address these limitations, this paper proposes a hybrid PII and operational security (OpSec) risk detection framework that integrates rule-based and machine learning approaches with an attacker-aware reasoning model. The system combines structured PII detection, contextual OpSec signal extraction, and multi-signal risk composition to identify higher-level privacy risks. In addition, it provides user-facing explanations and privacy-preserving rewrite suggestions, enabling proactive risk mitigation before content publication.

The proposed system is implemented as part of the Guardian framework and evaluated using a curated dataset of realistic social media scenarios. The results indicate that reasoning-based risk composition supports interpretable privacy risk assessment, particularly in multi-signal cases, while also highlighting challenges in handling ambiguity and calibration.

The main contributions of this work are as follows:

- A hybrid PII detection framework combining rule-based and transformer-based methods.
- A contextual OpSec signal extraction mechanism for identifying implicit privacy risks.
- An attacker-aware risk composition model capturing multi-signal interactions.
- An explainable user feedback system with explanation and safe rewrite generation.
- A structured system-level evaluation covering detection, reasoning, and user interaction quality.

II. RELATED WORK

A. PII Detection in Text

Automated detection of Personally Identifiable Information (PII) has been widely studied in Natural Language Processing (NLP). Early approaches relied on rule-based methods, such as regular expressions, to identify structured entities including phone numbers, email addresses, and identification numbers. These methods remain useful for well-defined formats because they provide deterministic matching and high precision. However, they lack flexibility when applied to informal, noisy, or context-dependent text.

Named Entity Recognition (NER) provides a foundation for detecting unstructured entities such as names, organizations, and locations [7]. Transformer-based models such as BERT, RoBERTa, and DistilBERT further improved contextual language representation for entity recognition and classification tasks [2], [8], [9]. Nevertheless, recent privacy benchmarks show that even advanced models can struggle with context-sensitive PII relevance decisions and structured pattern recognition [10].

Practical PII protection systems increasingly combine recognizers, rule-based detectors, and anonymization modules. For example, Microsoft Presidio provides a pluggable PII detection and de-identification framework for text and images [11]. These systems demonstrate the value of modular

PII detection, but they primarily focus on identifying or masking sensitive entities rather than reasoning about attacker-exploitable combinations of signals.

B. Contextual Privacy and Inference Risks

Beyond explicit identifiers, privacy risk is strongly shaped by context. The privacy paradox literature shows that users often disclose personal information despite privacy concerns [12], while contextual integrity theory argues that privacy depends on whether information flow is appropriate within a given social context [13]. This supports the need for systems that evaluate not only whether information is personal, but whether its disclosure is risky in context.

In social media environments, sensitive information can be inferred from combinations of indirect signals such as time, location, routine, and behavioral cues. Prior work on privacy in social media identifies both identity disclosure and attribute disclosure as important risk categories [14]. Similarly, studies on de-anonymization show that seemingly limited public information can become identifying when combined with auxiliary data [15]. These findings motivate attacker-aware analysis of user-generated content.

Recent work has also examined inference risks in modern language models. Attribute inference defenses such as TRACE-RPS show that text can leak private attributes through subtle cues and that proactive mitigation can reduce inference success [4]. Broader machine learning privacy research, including model inversion, membership inference, and privacy inference attacks against language models, further demonstrates how adversaries can extract sensitive information from indirect or model-mediated signals [16]–[18].

Existing datasets such as PANORAMA provide synthetic yet realistic PII-rich online content for privacy risk analysis and model auditing [19]. PII-Bench further shows the need for evaluating not only PII detection but also relevance and contextual judgment in privacy protection systems [10]. These works support the need for evaluation methods that consider contextual and multi-signal privacy risks rather than isolated entity detection alone.

C. Social Media Disclosure and Proactive Protection

Prior research has explored sensitive disclosure detection in social media, including doxxing and second- or third-party information exposure [20]. However, many such approaches focus on detecting harmful disclosures after publication. In contrast, proactive protection requires analyzing the content before it is posted and guiding the user at the point of content creation.

This distinction is important because privacy and security harms often occur when users underestimate how ordinary details can be combined. Differential privacy and anonymization research shows that protecting individual data requires careful control over what information can be inferred, not merely removal of obvious identifiers [21]. Similarly, OWASP identifies sensitive information disclosure as a major risk in LLM-based systems, reinforcing the importance of data minimization and careful handling of user-provided content [22].

D. User-Centered Privacy, Explainability, and Rewriting

A major limitation of existing privacy detection systems is the lack of user-centered design. Many approaches provide binary outputs without meaningful explanations or actionable guidance, which contributes to security fatigue [5]. Privacy fatigue research similarly shows that repeated exposure to privacy decisions can reduce user engagement with privacy-protective behavior [23]. Therefore, systems intended for real users must provide clear, actionable, and minimally disruptive feedback.

Research in usable security emphasizes the importance of designing systems that support user decision-making through clear and interpretable guidance [6]. Explainable AI research further supports the need for transparent reasoning in automated decision systems [24]. In privacy-sensitive settings, explanations are particularly important because users must understand not only that a risk exists, but why a specific disclosure may be harmful.

Recent work in contextual privacy has introduced approaches that go beyond detection by generating privacy-preserving text rewrites [3]. Related work on privacy and utility in personal LLM writing tasks highlights the trade-off between reducing sensitive information and preserving the usefulness or naturalness of generated text [25]. These studies support the design of systems that combine detection, explanation, and rewrite-based mitigation.

E. Limitations of Existing Approaches

Despite these advances, several key limitations remain. First, most systems treat PII detection and contextual risk analysis as separate problems, failing to capture how multiple signals interact to produce higher-level privacy risks. Second, existing approaches rarely incorporate an explicit attacker-aware perspective, which is necessary for understanding how adversaries interpret and exploit combined information. Third, user-facing capabilities such as explanation and mitigation are often limited, even though privacy and usable security research emphasize the importance of understandable and actionable feedback.

To address these gaps, this work proposes a unified framework that integrates hybrid PII detection, contextual OpSec signal extraction, and multi-signal risk composition within an attacker-aware reasoning model. In addition, the system provides explainable outputs and privacy-preserving rewrite suggestions, enabling proactive and user-centric risk mitigation.

III. METHODOLOGY

A. System Overview

The proposed system is designed as a hybrid, multi-layered framework for detecting and mitigating privacy and operational security (OpSec) risks in user-generated social media content. The system follows a three-stage pipeline consisting of: (1) evidence extraction, (2) risk composition, and (3) user interaction. This design enables the system to move beyond

isolated entity detection and instead model how multiple signals contribute to actionable privacy risks.

At a high level, the system processes input text and produces a structured output including a risk level (low, medium, high), detected signals, an explanation of the risk, and a privacy-preserving rewrite suggestion. The architecture is implemented as a backend service integrated with a browser-based interface, allowing real-time analysis prior to content publication.

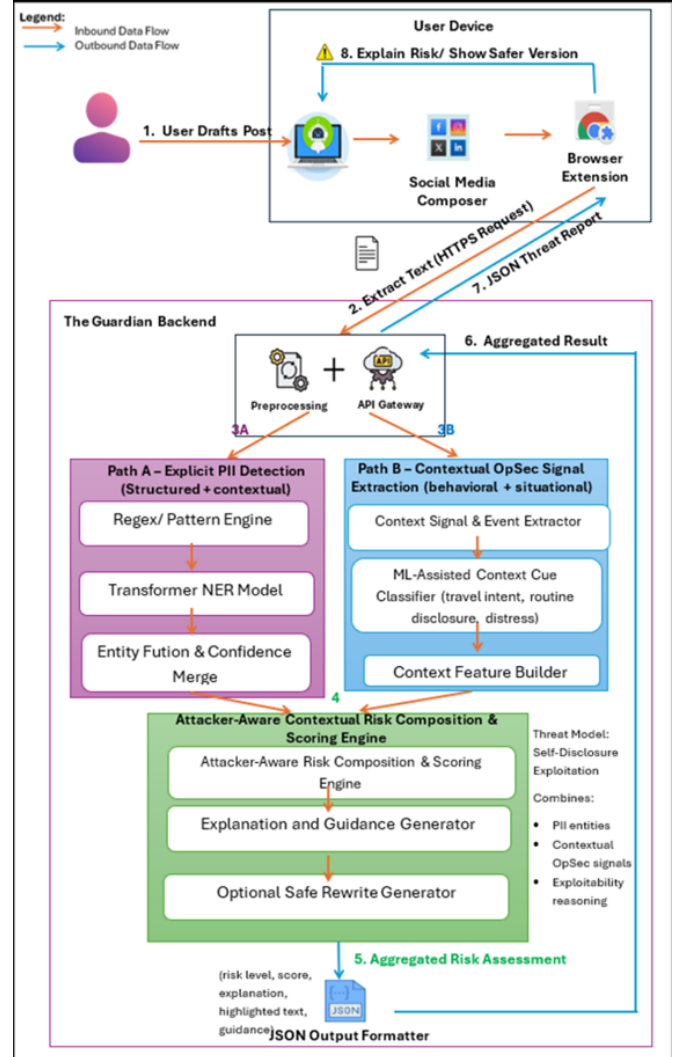


Fig. 1. Architecture of the proposed PII and OpSec module showing evidence extraction, risk composition, and user interaction layers.

B. Evidence Extraction Layer

The evidence extraction layer identifies both explicit and implicit signals from input text through two parallel components: PII detection and contextual OpSec signal extraction.

1) **Hybrid PII Detection:** To achieve comprehensive coverage, a hybrid detection strategy is adopted. Structured PII such as phone numbers, email addresses, and national identification numbers is detected using rule-based techniques, including regular expressions. These methods provide high precision for well-defined formats.

In parallel, contextual PII entities such as names, organizations, and locations are detected using machine learning-based Named Entity Recognition (NER) models built on transformer architectures [2], [8], [9]. These models enable the system to capture semantic and contextual variations in informal text.

This hybrid approach is motivated by prior work demonstrating that rule-based systems excel at structured pattern recognition, while transformer-based models provide stronger generalization for unstructured entities [10]. By combining both methods, the system achieves improved robustness across diverse input scenarios.

2) *Contextual OpSec Signal Extraction*: In addition to explicit identifiers, the system extracts contextual signals that may contribute to operational security risks. These signals are derived from behavioral and situational cues within the text, including:

- Future travel plans
- Real-time location disclosures
- Absence from home indicators
- Routine and predictability patterns
- Vulnerability or distress signals

These signals are detected using a combination of rule-based heuristics and lightweight classification strategies. Unlike traditional PII detection, this component focuses on interpreting the contextual meaning of the text rather than identifying explicit entities.

This design is aligned with research on inference-based privacy risks, where multiple weak signals can collectively reveal sensitive information [4].

C. Risk Composition Layer

The risk composition layer integrates signals from both PII and OpSec detection components to produce a unified risk assessment. Each detected signal is assigned a base weight based on its potential exploitability and severity.

The overall risk score is computed using a weighted aggregation strategy that considers both individual signal contributions and interaction effects. Interaction rules are defined to model scenarios where combinations of signals increase risk beyond their individual contributions. For example, the combination of travel plans and absence from home indicates a potential opportunity window for attackers.

The final risk score is mapped to discrete categories (low, medium, high) using calibrated thresholds. This design allows the system to maintain interpretability while capturing complex multi-signal interactions.

D. Attacker-Aware Reasoning

A key contribution of this work is the incorporation of an attacker-aware perspective in risk assessment. Rather than treating signals independently, the system evaluates how an adversary could interpret and exploit the available information.

This approach is motivated by prior research on inference attacks and contextual privacy, which shows that attackers can derive sensitive attributes from indirect signals [4]. By modeling these inference pathways explicitly, the system is able

to identify risks that would not be captured by conventional classification-based approaches.

E. Explanation and User Interaction Layer

To improve usability and user trust, the system includes an explanation layer that translates technical risk assessments into human-understandable reasoning. The explanation is generated based on the contribution trace from the risk composition layer and highlights the key factors influencing the risk level.

In addition, the system provides actionable guidance through a privacy-preserving rewrite mechanism. This component modifies the original text to reduce risk while preserving user intent. The rewrite process is signal-aware and applies targeted transformations, such as:

- Removing structured identifiers (e.g., phone numbers)
- Generalizing temporal expressions (e.g., “tomorrow” to “soon”)
- Reducing location specificity

For high-risk structured disclosures, such as full addresses, the system applies conservative generalization to prevent residual information leakage. This design is consistent with prior work on contextual privacy-preserving rewriting [3].

F. Implementation Details

The system is implemented as a modular backend service using a REST-based API. The analysis pipeline is exposed through an endpoint that processes input text and returns structured outputs, including risk level, detected signals, explanation, and rewrite suggestion.

The modular design enables independent development and refinement of each component while supporting seamless integration into a browser-based user interface. This allows the system to function as a proactive decision-support tool, assisting users before content is published.

IV. EVALUATION SETUP

A. Evaluation Objectives

The evaluation is designed to assess the effectiveness of the proposed system in detecting and mitigating privacy and operational security (OpSec) risks in user-generated social media content. Unlike traditional NLP evaluation settings that focus solely on classification accuracy, this study adopts a system-level evaluation perspective that considers both detection performance and user-facing utility.

Specifically, the evaluation aims to measure:

- The accuracy of risk detection across diverse scenarios
- The correctness and completeness of identified signals
- The quality and interpretability of generated explanations
- The effectiveness of privacy-preserving rewrite suggestions

This multi-dimensional evaluation aligns with prior work in usable security and explainable AI, which emphasizes the importance of human-centered assessment in security systems [6], [24].

B. Dataset Design

A controlled evaluation dataset consisting of 25 test cases was constructed to simulate realistic social media posting scenarios. The dataset is deliberately balanced across five categories representing different privacy risk conditions:

- Safe benign content
- Explicit PII disclosures
- Contextual OpSec signals
- Combined PII and OpSec cases
- Ambiguous or borderline scenarios

Each category contains five test cases, ensuring consistent coverage across varying levels of risk complexity. The dataset includes both straightforward and edge-case examples to evaluate system robustness under ambiguity and multi-signal interactions.

This controlled dataset design follows methodologies used in prior privacy-risk evaluation frameworks, where curated scenarios are employed to systematically assess system behavior under diverse conditions [10], [19].

TABLE I
DISTRIBUTION OF EVALUATION DATASET ACROSS PREDEFINED RISK CATEGORIES.

Category	Number of Cases
Safe	5
PII	5
OpSec	5
Combined	5
Ambiguous	5
Total	25

C. Evaluation Dimensions

To capture both technical performance and user-facing quality, the system is evaluated across four key dimensions:

1) Risk Detection Accuracy: Measures whether the predicted risk level (low, medium, high) aligns with the expected classification.

2) Signal Detection Quality: Evaluates whether relevant PII and OpSec signals are correctly identified and whether critical signals are missed or incorrectly inferred.

3) Explanation Quality: Assesses the clarity, correctness, and relevance of generated explanations. This dimension evaluates whether explanations accurately reflect the detected signals and provide understandable reasoning.

4) Rewrite Effectiveness: Measures the ability of the system to generate privacy-preserving alternatives that reduce risk while maintaining semantic meaning and linguistic naturalness.

These dimensions reflect a shift from purely algorithmic evaluation toward holistic system validation, consistent with research in explainable and user-centered AI systems [3], [24].

D. Evaluation Methodology

The evaluation follows a hybrid methodology combining automated analysis with structured manual assessment. For each test case, the system processes the input text and produces

outputs including risk level, detected signals, explanation, and rewrite suggestion.

The outputs are evaluated using predefined criteria:

- Risk correctness (Correct / Incorrect)
- Explanation clarity (Good / Partial / Poor)
- Explanation relevance (Good / Partial / Poor)
- Rewrite risk reduction (Good / Partial / Poor)
- Rewrite meaning preservation (Good / Partial / Poor)
- Rewrite naturalness (Good / Partial / Poor)

Manual evaluation is applied to subjective components such as explanation quality and rewrite effectiveness. This approach is necessary because such attributes cannot be reliably captured through automated metrics alone and require human judgment, as supported by prior work in usable security evaluation [6].

E. Implementation and Execution

The evaluation was conducted using a structured testing pipeline in which each input was processed through the system backend via an API interface. The outputs were recorded in a tabular format for subsequent analysis.

In addition to correctness metrics, processing time was captured for each test case to assess system responsiveness. This is particularly important for real-time applications where latency directly impacts usability.

F. Evaluation Scope and Limitations

The evaluation is designed to provide a detailed qualitative and quantitative analysis of system behavior across representative scenarios. However, the dataset size is limited and does not reflect large-scale real-world distributions.

This controlled evaluation approach prioritizes interpretability and diagnostic analysis over statistical generalization. Similar evaluation strategies are commonly used in early-stage system validation to identify strengths, weaknesses, and failure modes before large-scale deployment [10].

Future work will extend this evaluation to larger datasets and real-world user studies to further validate system performance and usability.

V. RESULTS AND ANALYSIS

A. Overall Performance

The system was evaluated on a dataset of 25 test cases spanning five categories of privacy risk scenarios. Table II summarizes the overall detection performance.

TABLE II
OVERALL DETECTION PERFORMANCE

Metric	Value
Total Test Cases	25
Correct Predictions	18
Incorrect Predictions	7
Accuracy (%)	72

The system achieves an overall accuracy of 72%, indicating consistent performance across diverse input scenarios. Given the inclusion of ambiguous and multi-signal cases, this result

reflects the system’s ability to balance detection sensitivity with contextual reasoning.

B. Category-wise Performance

To better understand system behavior, performance was analyzed across individual risk categories. The results are presented in Table III.

TABLE III
CATEGORY-WISE PERFORMANCE

Category	Total	Correct	Accuracy (%)
Safe	5	2	40
PII	5	4	80
OpSec	5	4	80
Combined	5	5	100
Ambiguous	5	4	80

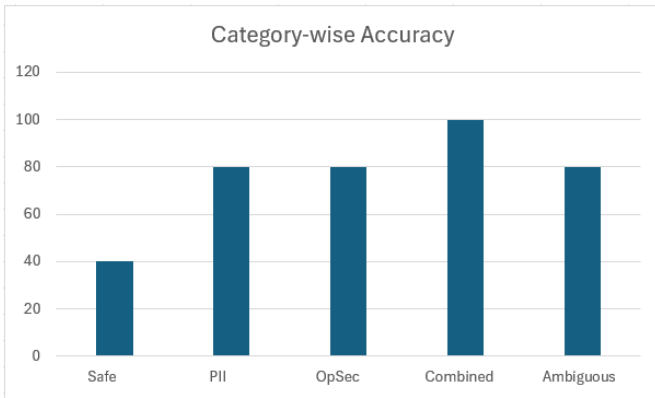


Fig. 2. Category-wise accuracy of the proposed system across different risk scenarios.

The category-wise performance is further illustrated in Fig. 2, highlighting strong performance in combined scenarios and reduced accuracy in safe content.

The system demonstrates its strongest performance in combined PII and OpSec cases, achieving 100% accuracy. This result highlights the effectiveness of the risk composition layer in handling multi-signal interactions, which are typically challenging for conventional detection systems.

Performance in explicit PII and OpSec categories remains consistently high at 80%, indicating that both structured detection and contextual signal extraction components operate reliably in isolation.

However, accuracy drops significantly for safe content (40%), revealing a tendency toward over-triggering. This behavior indicates that the system prioritizes sensitivity over precision, favoring early detection of potential risks at the cost of increased false positives.

C. Explanation Quality

The quality of generated explanations was evaluated using structured manual assessment. The distribution is shown in Table IV.

TABLE IV
EXPLANATION QUALITY DISTRIBUTION

Quality Level	Count
Good	12
Partial	12
Poor	1

The majority of explanations are classified as good or partial, demonstrating that the system generally provides understandable and relevant reasoning. Importantly, explanations consistently reflect detected signals and their implications, supporting interpretability.

The low number of poor explanations suggests that the explanation generation mechanism is stable, although further refinement is required to improve consistency and depth.

D. Rewrite Effectiveness

The effectiveness of privacy-preserving rewrites was evaluated across three criteria: risk reduction, meaning preservation, and naturalness. The aggregated results are presented in Table V.

TABLE V
REWRITE QUALITY DISTRIBUTION

Quality Level	Count
Good	10
Partial	5
Poor	10

The rewrite component exhibits mixed performance. While a portion of outputs effectively reduce risk while preserving meaning, a comparable number are rated as poor due to incomplete removal of sensitive content or reduced linguistic naturalness.

This result highlights the inherent difficulty of balancing privacy preservation with semantic fidelity, particularly in cases involving structured disclosures such as addresses or compound signals.

E. Error Analysis

To better understand system limitations, error patterns were analyzed and categorized, as shown in Table VI.

TABLE VI
ERROR ANALYSIS

Error Type	Count
Over-triggering (Safe / Real-time / Absence)	5
Partial Signal Coverage	3
Signal Over-detection	2
Weak Ambiguity Handling	2
Vulnerability Over-interpretation	2
Address Handling Issues	2
Missed Risk Calibration	1

The most frequent issue is over-triggering in safe or low-risk scenarios. This is primarily driven by strong weighting of temporal and absence-related signals, which can lead to conservative risk classification.

Other observed limitations include incomplete signal detection, challenges in interpreting ambiguous inputs, and inconsistencies in handling structured address information. These findings suggest that improvements in contextual calibration and signal weighting could significantly enhance system precision.

F. Interpretation of Results

The results demonstrate that the proposed system is particularly effective in scenarios involving multiple interacting signals. The perfect performance in combined cases indicates that the risk composition layer successfully models higher-level inference patterns that are often missed by traditional detection approaches.

At the same time, the system exhibits a clear trade-off between sensitivity and precision. The tendency to over-trigger in safe scenarios suggests that the system is optimized for early risk detection, which is desirable in user-facing security applications but may require further calibration.

Importantly, the results confirm that integrating reasoning-based risk composition supports both detection and interpretability in multi-signal privacy risk assessment, even without significant changes to the underlying detection models. This supports the central hypothesis of this work that system-level reasoning plays a critical role in effective privacy risk assessment.

VI. DISCUSSION

The evaluation results demonstrate that the proposed hybrid system effectively identifies and interprets privacy risks in user-generated content, particularly in scenarios involving multiple interacting signals. The system achieves its strongest performance in combined PII and OpSec cases, indicating that the integration of evidence extraction and risk composition enables robust multi-signal reasoning.

The high accuracy observed in explicit PII and OpSec categories further validates the effectiveness of the hybrid detection strategy. This aligns with prior work showing that combining rule-based and machine learning approaches improves robustness in real-world text processing tasks [26]. The ability to capture both structured identifiers and contextual cues highlights the advantage of hybrid architectures over single-method detection systems.

However, the evaluation also reveals important limitations. The system exhibits over-triggering behavior in safe and low-risk scenarios, resulting in reduced precision. This reflects a sensitivity-oriented design, where the system prioritizes early detection of potential risks at the cost of increased false positives. Similar trade-offs between sensitivity and precision have been observed in security and privacy warning systems, where excessive or low-relevance alerts can contribute to user fatigue [5].

In addition, the rewrite component demonstrates variability in performance. While many rewrites successfully reduce risk while preserving meaning, others fail to sufficiently transform sensitive content or maintain natural language quality. This

highlights the broader challenge of balancing privacy preservation with linguistic fidelity, a problem also identified in recent work on privacy-aware text rewriting systems [27].

Error analysis further reveals challenges in ambiguity handling and partial signal coverage. Cases involving implicit context or weak signals are more difficult for the system to interpret accurately. This limitation is consistent with findings in contextual privacy research, where inference-based risks depend heavily on nuanced interpretation of user intent and situational context [28].

Overall, the results indicate that the proposed system prioritizes sensitivity over precision, favoring early risk detection in user-facing applications. This design choice is appropriate for proactive privacy protection systems, where missing a critical risk may have more severe consequences than issuing occasional false positives.

VII. CONCLUSION

This paper presented a hybrid PII and operational security (OpSec) risk detection framework designed for proactive, user-facing privacy protection in social media environments. Unlike traditional approaches that focus solely on explicit identifier detection, the proposed system integrates structured PII detection, contextual OpSec signal extraction, and an attacker-aware risk composition layer to model inference-based privacy risks.

The system demonstrates strong performance across diverse scenarios, achieving an overall accuracy of 72% and 100% accuracy in combined multi-signal cases. These results suggest the practical value of integrating evidence extraction with reasoning-based risk composition, particularly in scenarios where risks emerge from the interaction of multiple weak signals. Furthermore, the system provides interpretable explanations and privacy-preserving rewrite suggestions, supporting informed user decision-making prior to content publication.

The findings confirm that system-level reasoning plays a critical role in privacy risk detection, extending beyond the capabilities of isolated detection models. By incorporating an attacker-aware perspective, the system is able to identify higher-level risks that would otherwise remain undetected in conventional approaches. This aligns with emerging research emphasizing the importance of contextual and inference-aware privacy protection mechanisms [4], [28].

Despite these strengths, several limitations remain. The system exhibits a sensitivity-precision trade-off, leading to over-triggering in safe or low-risk scenarios. In addition, the rewrite component demonstrates variability in balancing risk reduction with linguistic naturalness. These challenges highlight the need for improved calibration strategies and more advanced language generation techniques.

Future work will focus on expanding the evaluation to larger and more diverse datasets, incorporating user feedback for iterative refinement, and exploring advanced reasoning models to improve ambiguity handling. Additionally, integrating adaptive risk calibration mechanisms could further balance sensitivity and precision in real-world deployments.

Overall, this work demonstrates that combining hybrid detection, contextual reasoning, and user-centric interaction provides a promising direction for next-generation privacy-aware systems. The proposed framework contributes toward bridging the gap between detection and actionable privacy protection, enabling more effective and practical safeguards in modern social media environments.

REFERENCES

- [1] A. Acquisti, L. Brandimarte, and G. Loewenstein, "Privacy and Human Behavior in the Age of Information," *Science*, vol. 347, no. 6221, pp. 509–514, 2015.
- [2] J. Devlin, M.-W. Chang, K. Lee, and K. Toutanova, "BERT: Pre-training of Deep Bidirectional Transformers for Language Understanding," in *Proc. NAACL*, 2019.
- [3] I. C. Ngong, S. R. Kadhe, H. Wang, K. Murugesan, J. D. Weisz, A. Dhurandhar, and K. N. Ramamurthy, "Protecting Users From Themselves: Safeguarding Contextual Privacy in Interactions with Conversational Agents," in *Findings of the Association for Computational Linguistics: ACL 2025*, pp. 26196–26220, 2025.
- [4] D. Yan, J. Liang, R. He, and T. Tan, "Stop Tracking Me! Proactive Defense Against Attribute Inference Attack in LLMs," in *Proc. International Conference on Learning Representations (ICLR)*, 2026, arXiv:2602.11528.
- [5] B. Stanton, M. F. Theofanos, S. S. Prettyman, and S. Furman, "Security Fatigue," *IT Professional*, vol. 18, no. 5, pp. 26–32, 2016.
- [6] S. Egelman and E. Peer, "Scaling the Security Wall: Developing a Security Behavior Intentions Scale (SeBIS)," in *Proc. CHI*, pp. 2873–2882, 2015.
- [7] D. Nadeau and S. Sekine, "A Survey of Named Entity Recognition and Classification," *Linguisticae Investigationes*, vol. 30, no. 1, pp. 3–26, 2007.
- [8] Y. Liu et al., "RoBERTa: A Robustly Optimized BERT Pretraining Approach," *arXiv preprint arXiv:1907.11692*, 2019.
- [9] V. Sanh, L. Debut, J. Chaumond, and T. Wolf, "DistilBERT, a Distilled Version of BERT: Smaller, Faster, Cheaper and Lighter," *arXiv preprint arXiv:1910.01108*, 2019.
- [10] H. Shen, Z. Gu, H. Hong, and W. Han, "PII-Bench: Evaluating Query-Aware Privacy Protection Systems," *arXiv preprint arXiv:2502.18545*, 2025.
- [11] Microsoft, "Presidio: Data Protection and De-identification SDK," Microsoft, 2024. [Online]. Available: <https://microsoft.github.io/presidio/>
- [12] M. Taddicken, "The Privacy Paradox in the Social Web: The Impact of Privacy Concerns, Individual Characteristics, and the Perceived Social Relevance on Different Forms of Self-Disclosure," *Journal of Computer-Mediated Communication*, vol. 19, no. 2, pp. 248–273, 2014.
- [13] H. Nissenbaum, *Privacy in Context: Technology, Policy, and the Integrity of Social Life*. Stanford, CA, USA: Stanford University Press, 2010.
- [14] G. Beigi and H. Liu, "Privacy in Social Media: Identification, Mitigation and Applications," *arXiv preprint arXiv:1808.02191*, 2018.
- [15] A. Narayanan and V. Shmatikov, "De-anonymizing Social Networks," in *Proc. IEEE Symposium on Security and Privacy*, pp. 173–187, 2009.
- [16] M. Fredrikson, S. Jha, and T. Ristenpart, "Model Inversion Attacks that Exploit Confidence Information and Basic Countermeasures," in *Proc. ACM CCS*, pp. 1322–1333, 2015.
- [17] R. Shokri, M. Stronati, C. Song, and V. Shmatikov, "Membership Inference Attacks Against Machine Learning Models," in *Proc. IEEE Symposium on Security and Privacy*, pp. 3–18, 2017.
- [18] A. Staab et al., "Beyond Memorization: Violating Privacy via Inference with Large Language Models," in *Proc. ICLR*, 2024.
- [19] S. Selvam and A. Ghosh, "PANORAMA: A Synthetic PII-laced Dataset for Studying Sensitive Data Memorization in LLMs," *arXiv preprint arXiv:2505.12238*, 2025.
- [20] Y. Karimi, Y. Tang, and T. Abdelzaher, "Detecting and Mitigating Sensitive Information Disclosure on Social Media," *arXiv preprint arXiv:2202.00879*, 2022.
- [21] C. Dwork, "Differential Privacy," in *Proc. ICALP*, pp. 1–12, 2006.
- [22] OWASP Foundation, "LLM02: Sensitive Information Disclosure," OWASP Top 10 for Large Language Model Applications, 2025. [Online]. Available: <https://genai.owasp.org/>
- [23] H. Choi, J. Park, and Y. Jung, "The Role of Privacy Fatigue in Online Privacy Behavior," *Computers in Human Behavior*, vol. 81, pp. 42–51, 2018.
- [24] A. Adadi and M. Berrada, "Peeking Inside the Black-Box: A Survey on Explainable Artificial Intelligence (XAI)," *IEEE Access*, vol. 6, pp. 52138–52160, 2018.
- [25] S. Pasch et al., "Balancing Privacy and Utility in Personal LLM Writing Tasks," in *Proc. Workshop on Privacy in NLP*, pp. 32–41, 2025.
- [26] I. Keraghel, S. Morbieu, and M. Nadif, "Recent Advances in Named Entity Recognition: A Comprehensive Survey and Comparative Study," *arXiv preprint arXiv:2401.10825*, 2024.
- [27] S. Feyisetan, B. Diethe, and T. Drake, "Leveraging Hierarchical Representations for Preserving Privacy and Utility in Text," in *Proc. IEEE ICDM Workshops*, 2020.
- [28] A. Shvartzshnaider et al., "Learning Privacy Expectations by Crowdsourcing Contextual Informational Norms," in *Proc. AAAI HCOMP*, 2016.